

OWASP Core Business Application Security



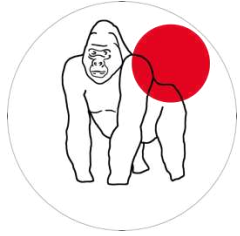
95



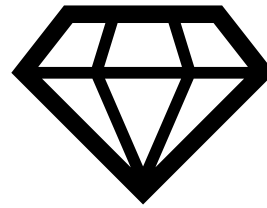
311

Waseem Ajrab, NO MONKEY
Jonathan Stross, Pathlock





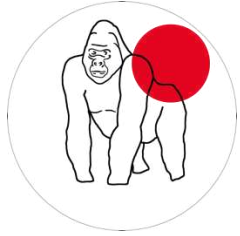
Lack of Security Hygiene



Crown Jewels



Gold Mine



SAP Complexity...

Is it a blessing or curse?!



SAP Complexity – Application Level OWASP®

9,5

12

40

44

50

67

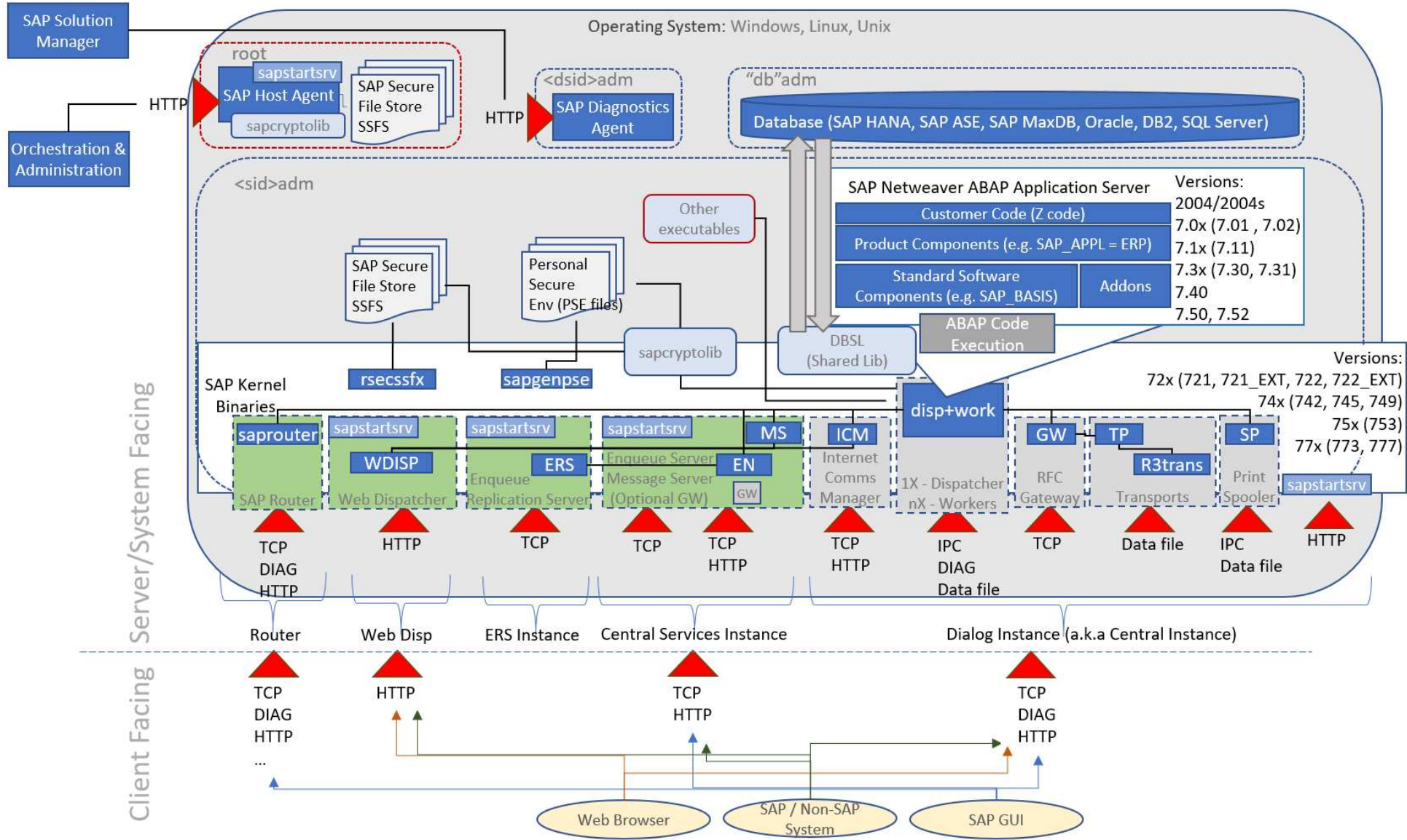
84

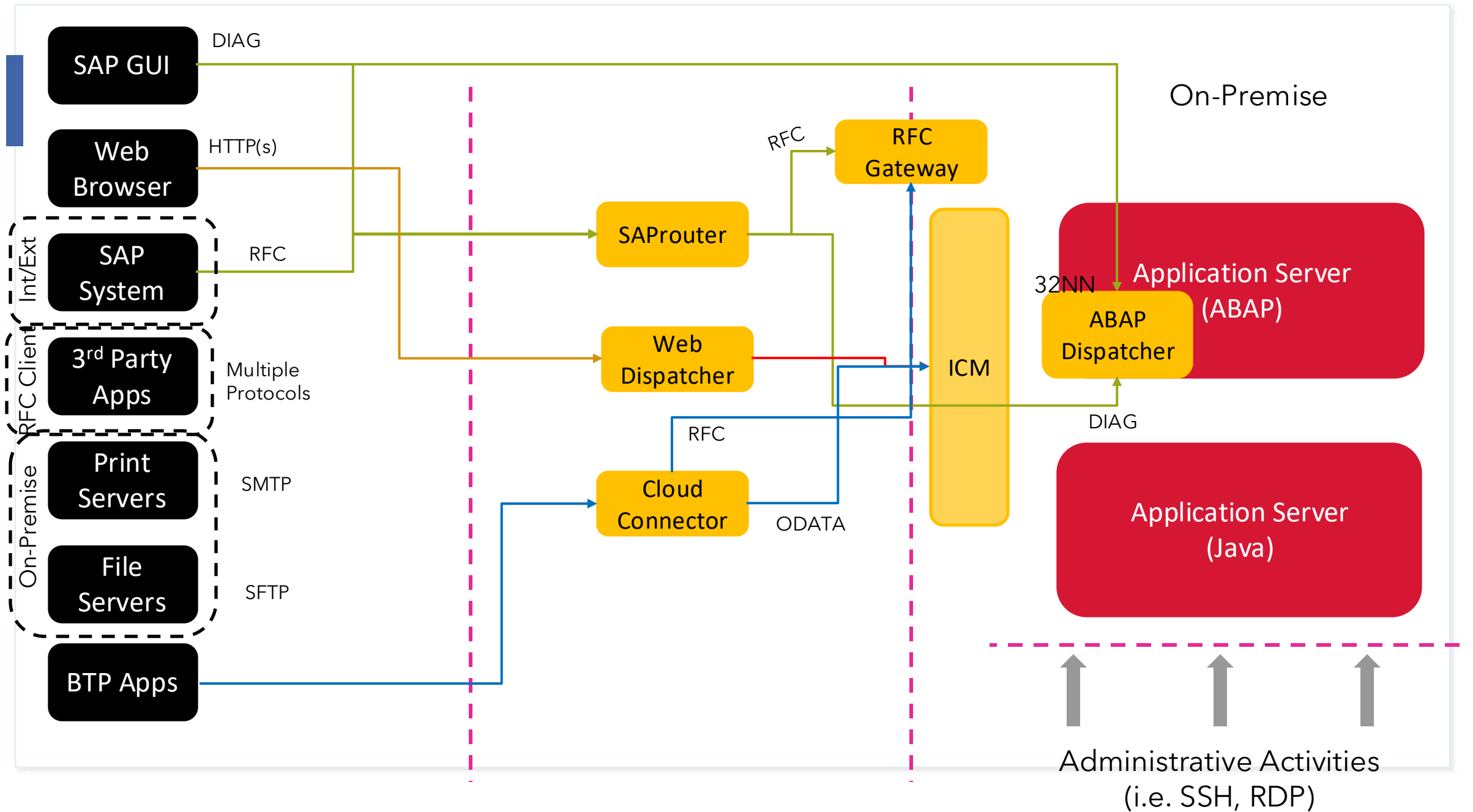


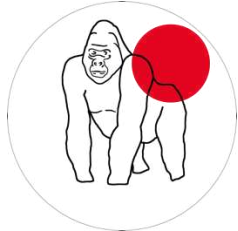
SAP Business Suite 319 Million Lines of Code (!)



SAP ERP 6.0 Entry Points



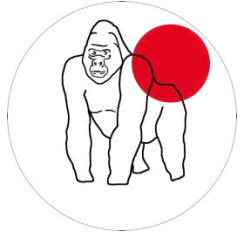




SAP Goes to Cloud



SAP Enterprise Cloud Services RISE with SAP S/4HANA Cloud, private edition and SAP ERP, tailored option			ROLES AND RESPONSIBILITIES	
Row	Identifier	Task	Responsibility	
410		Disaster Recovery	Disaster Recovery is an Optional Service and is only provided in the managed service if Disaster Recovery is part of the contract/SOW/Order Form and/or added with a Change Request.	
411	BASIC_1.9.01	Implement disaster recovery set-up according to architecture blueprint and contractual specifications. Test managed service internal data center and technical system infrastructure.	Optional Services	
412	BASIC_1.9.02	Develop and use disaster recovery procedures for database and file system replication only.	Optional Services	
413	BASIC_1.9.03	Ongoing management of disaster recovery architecture: monitoring of data replication to secondary site including troubleshooting.	Optional Services	
414	BASIC_1.9.04	Ongoing management of disaster recovery architecture: maintenance and change management for systems at secondary site to ensure system consistency including troubleshooting.	Optional Services	
415	BASIC_1.9.05	Develop and maintain disaster recovery procedures for those areas and aspects of the service which are in customer responsibility.	Excluded Tasks	
416	BASIC_1.9.06	Execute failover during disaster recovery test (DB, application and names) - additional	Optional Services	
417	BASIC_1.9.10	Execute failover during disaster recovery test (DB, application and names) - additional	Additional Service	
418	BASIC_1.9.09	Execute online disaster recovery tests (data center and technical system infrastructure only); primary systems remain accessible.	Additional Service	
419	BASIC_1.9.07	Execute productive failover in case of an officially declared disaster by service provider - only); primary systems remain accessible.	Optional Services	
420	BASIC_1.9.11	Execute productive failover in case of an officially declared disaster by service provider - only); primary systems remain accessible.	Optional Services	
421	BASIC_1.9.12	Mixed High Availability (HA)/Disaster Recovery (DR): Execute productive failover for a specific SID and invert replication vector.	Additional Service	
422	BASIC_1.15.01	Mixed High Availability (HA)/Disaster Recovery (DR): Execute productive failover for a specific SID and invert replication vector - additional customer requests.	These services provide possible extensions to areas of Incident, Change and Event Management beyond the standard scope of services.	
423	BASIC_1.15.02	Operations Extension	SAP Cloud Application Services ("CAS") available at additional charge. Needs to be performed by customer if applicable and if the SAP CAS Service is not used.	
424	BASIC_1.15.03	Analyze Technical Issue - SAP Basis / Customer Client	SAP Cloud Application Services ("CAS") available at additional charge. Needs to be performed by customer if applicable and if the SAP CAS Service is not used.	
425	BASIC_1.15.04	Change Management: Changes of technical system configuration not included in Standard Services as per R&R Definition.	SAP Cloud Application Services ("CAS") available at additional charge. Needs to be performed by customer if applicable and if the SAP CAS Service is not used.	
426	BASIC_1.15.05	Event management: Monitor technical/non-functional event types not included in Standard Service as per R&R Definition.	SAP Cloud Application Services ("CAS") available at additional charge. Needs to be performed by customer if applicable and if the SAP CAS Service is not used.	
427	BASIC_1.15.06	Service Request Fulfillment: Perform Service Request Fulfillment for technical/non-functional task not included in Standard Service as per R&R Definition.	SAP Cloud Application Services ("CAS") available at additional charge. Needs to be performed by customer if applicable and if the SAP CAS Service is not used.	

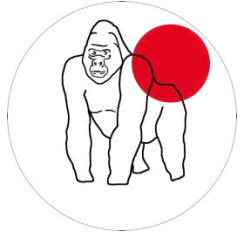


SAP Goes to AI

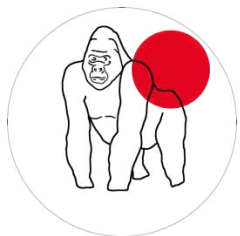


SAPwned: SAP AI vulnerabilities expose customers' cloud environments and private AI artifacts





72% of beer production in the world depends on SAP!





SAP Security Myths



ZERO TRUST



IAM & AUTHORIZATION



ENFORCING CONTROLS
ONLY ON PRODUCTION



SAP BASIS TEAM TAKES
CARE OF SECURITY



SAP SYSTEMS ARE
ISOLATED AND NOT
PUBLISHED



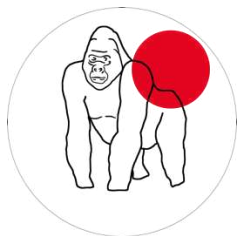
GERMAN MADE =
SECURE BY DEFAULT



Project Goals



- Provide a security standard to secure SAP systems
- Provide the necessary tools to verify security measures
- Provide a single point of trusted security advisors
- Enabling regulators and auditors to assess enterprise business solutions



OWASP Core Business Application Security

Security Assessment /
Penetration Testing

Deception

Adversary Simulation

Attack Surface
Management

HoneySAP

SAPKiln

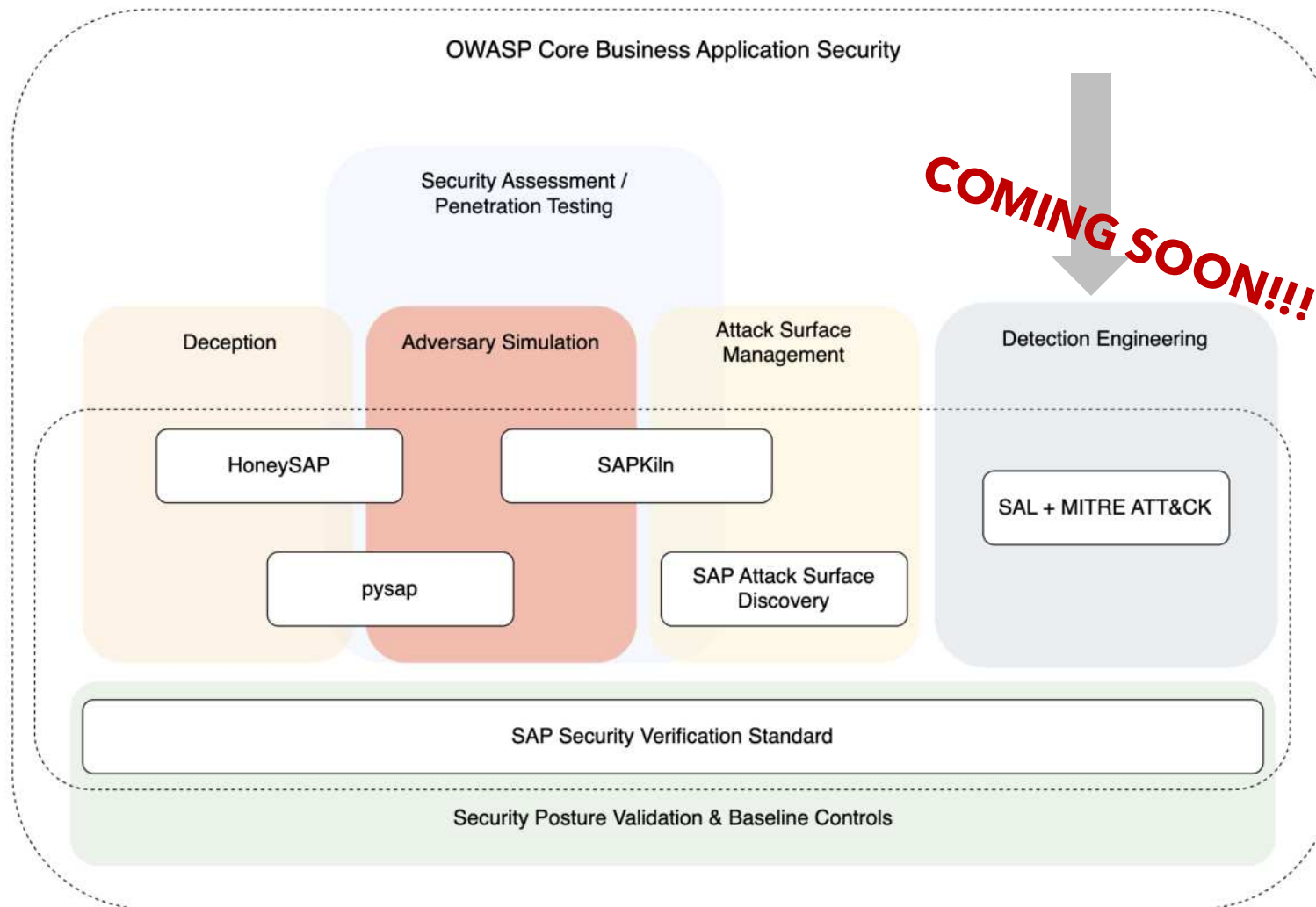
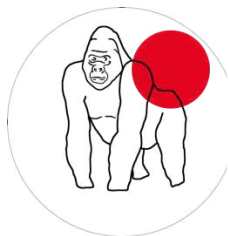
pysap

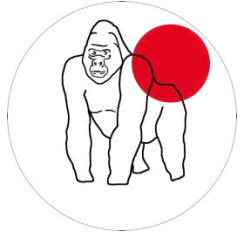
SAP Attack Surface
Discovery

SAP Security Verification Standard

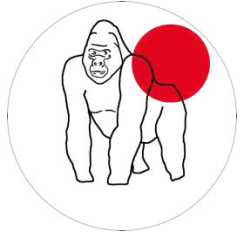
Security Posture Validation & Baseline Controls







SAP Security Verification Standard



Security Function	Category	Technology	Maturity Level	IPAC	Defender	Prerequisite
Protect (PT)	Identity Management, Authentication and Access Control (PT.AC)	SAP ABAP	1	Access (A)	Technology	PT-PA-IP-M01-001

Description

SAP standard users are required to be managed and securely configured to avoid any misuse to SAP systems. This includes changing default passwords and restricting standard users.

Implementation

The below standard users, found in ABAP systems, are required to be managed and securely configured: (The Verification of Control section will help organizations have the basic requirements to secure these users)

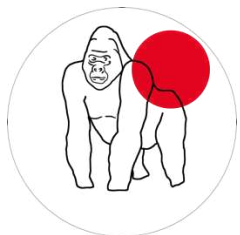
1. SAP*
2. DDIC
3. SAPCPIC
4. TMSADM
5. EARLYWATCH
6. Users created by the SAP solution manager



Verification of Control

- SAP*
 - Must exist in all clients
 - Must be locked in all clients
 - Default password must be changed
 - Must belong to the group SUPER in all clients
 - No profile should be assigned (especially SAP_ALL)
 - login/no_automatic_user_sapstar profile parameter must be set to 1
- DDIC
 - Default password must be changed
 - Must belong to the group SUPER in all clients
- SAPCPIC
 - Delete if user not required
 - If required, default password must be changed
 - Must belong to the group SUPER in all clients
- TMSADM
 - Default password must be changed
 - Should only exist in client 000
 - Must belong to the group SUPER in client 000
 - Authorization profile S_A.TMSADM should only be assigned
- EARLYWATCH
 - The user should not exist in any client
- Other users created by the SAP Solution Manager (SOLMAN_BTC, CONTENTSERV, SMD_BI_RFC, SMD_RFC, SMDAGENT_SAPSolutionManagerSID, SMD_ADMIN, SMD_AGT, SAPSUPPORT, SOLMAN_ADMIN)
 - Default password must be change





Security Function	Category	Technology	Maturity Level	SAP Operational Area	Prerequisite
Detect (DT)	Anomalies and Events (DT.AE)	SAP HANA	2	Access (A)	

Description

HANA audit trails should be written to either the system or tenant database. In the standard configuration, the audit trail parameters can only be changed in the system database.

Implementation

The parameter "default_audit_trail_type" must be set to either the value SYSLOGPROTOCOL or CSTORE. The value "SYSLOGPROTOCOL" means that the log is written to the system database, while the value "CSTORE" means that the log is written to the tenant database. This is done in the "global.ini" file in the "auditing configuration" section of the HANA database.

- ALTER SYSTEM ALTER CONFIGURATION ('global.ini', 'SYSTEM') set ('auditing configuration', 'default_audit_trail_type') = 'SYSLOGPROTOCOL';
- ALTER SYSTEM ALTER CONFIGURATION ('global.ini', 'SYSTEM') set ('auditing configuration', 'default_audit_trail_type') = 'CSTORE';

Verification of control

Check that the "default_audit_trail_type" parameter in the "global.ini" file in the "auditing configuration" section is assigned either the value SYSLOGPROTOCOL or CSTORE.

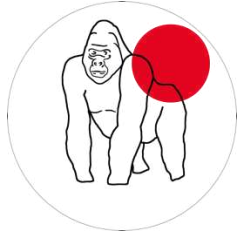


SAP Security Verification Standard



Support Areas:

- Updating, enhancing, and adding security controls
- Creation of a standard document
- Update Wiki
- Improve and simplify usability
 - Support teams in tracking and monitoring their progress



SAP Attack Surface Discovery



SAP Attack Surface Discovery

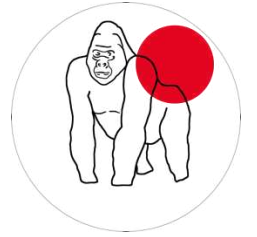


- Identification and discovery of SAP services
 - Identify exposed ports
 - Fingerprint services
- Demonstrate the risk of exposed SAP applications
- Provide visibility to non-SAP researchers and other





Where are we?



- Containerized environment
- Nuclei Templates
- Wiki section per service
- Collaboration with hunter.how
- Inclusion of Shodan queries

Services added so far:

- SAPRouter
- SAP Cloud Connector
- SAP Message Server
- SAP Dispatcher
- SAP Web Dispatcher
- SAP Start Service
- SAP RFC Gateway
- SAP Internet Graphics Server
- SAP ASE (DB)



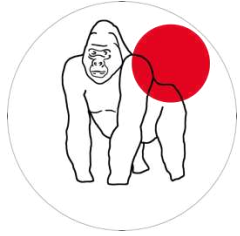


Roadmap



- Add more service i.e. SAP HANA, Web Services, SAP JAVA P4, etc
- Add more tools & references to the services
- Extend intergations with hunter.how
- Create integration with Pysap & SAPKiln projects





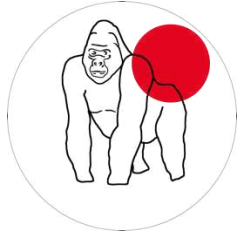
Pysap



Features



- Dissection and crafting of the following network protocols:
 - SAP Network Interface (NI)
 - SAP Diag
 - SAP Enqueue
 - SAP Router
 - SAP Message Server (MS)
 - SAP Secure Network Connection (SNC)
 - SAP Internet Graphic Server (IGS)
 - SAP Remote Function Call (RFC)
 - SAP HANA SQL Command Network (HDB)
- Client interfaces for handling the following file formats:
 - SAP [SAR archive files](#)
 - SAP Personal Security Environment (PSE) files
 - SAP SSO Credential (Credv2) files
 - SAP Secure Storage in File System (SSFS) files
- Library implementing SAP's LZH and LZC compression algorithms.
- Automatic compression/decompression of payloads with SAP's algorithms.
- Client, proxy and server classes implemented for some of the protocols.
- Example scripts to illustrate the use of the different modules and protocols.



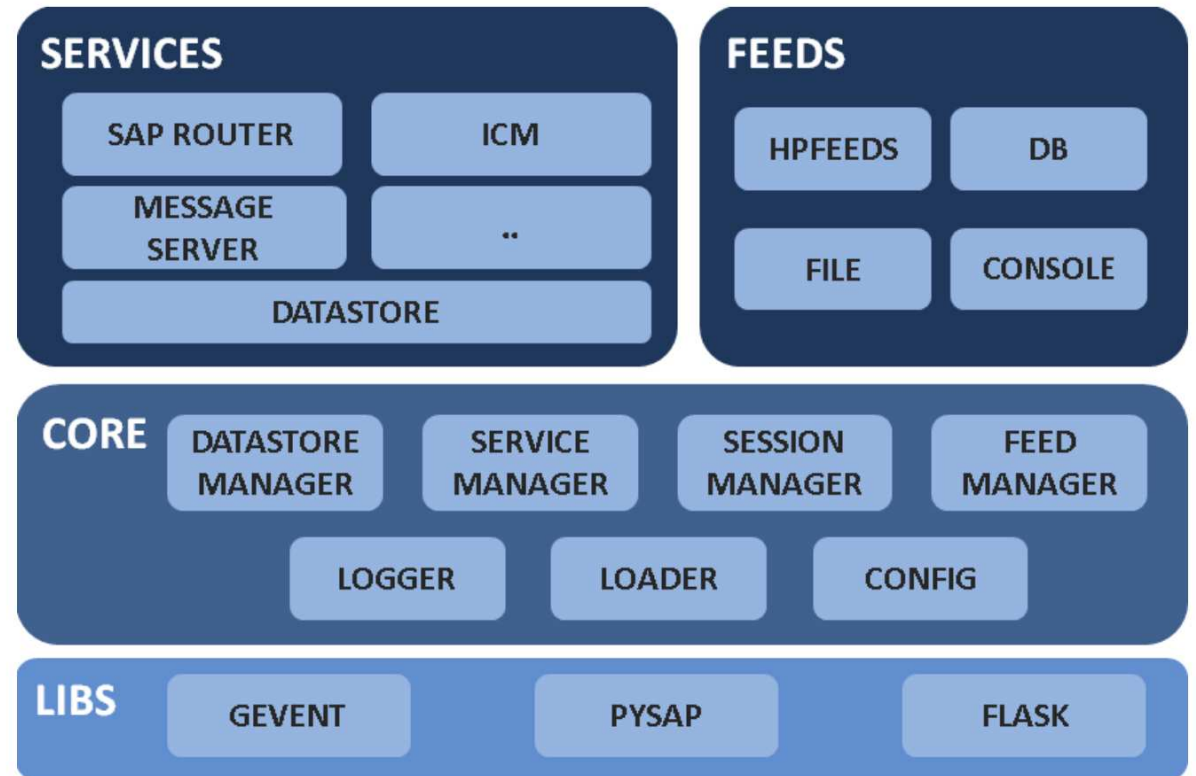
HoneySAP

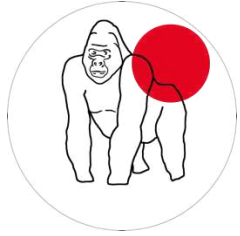


Features



- Low-interaction honeypot for SAP services
- YAML and JSON-based configuration
- Pluggable datastore backend
- Modular services system
- Modular feeds system
- Console logging





Mitre ATT&CK mapping of SAP SAL*



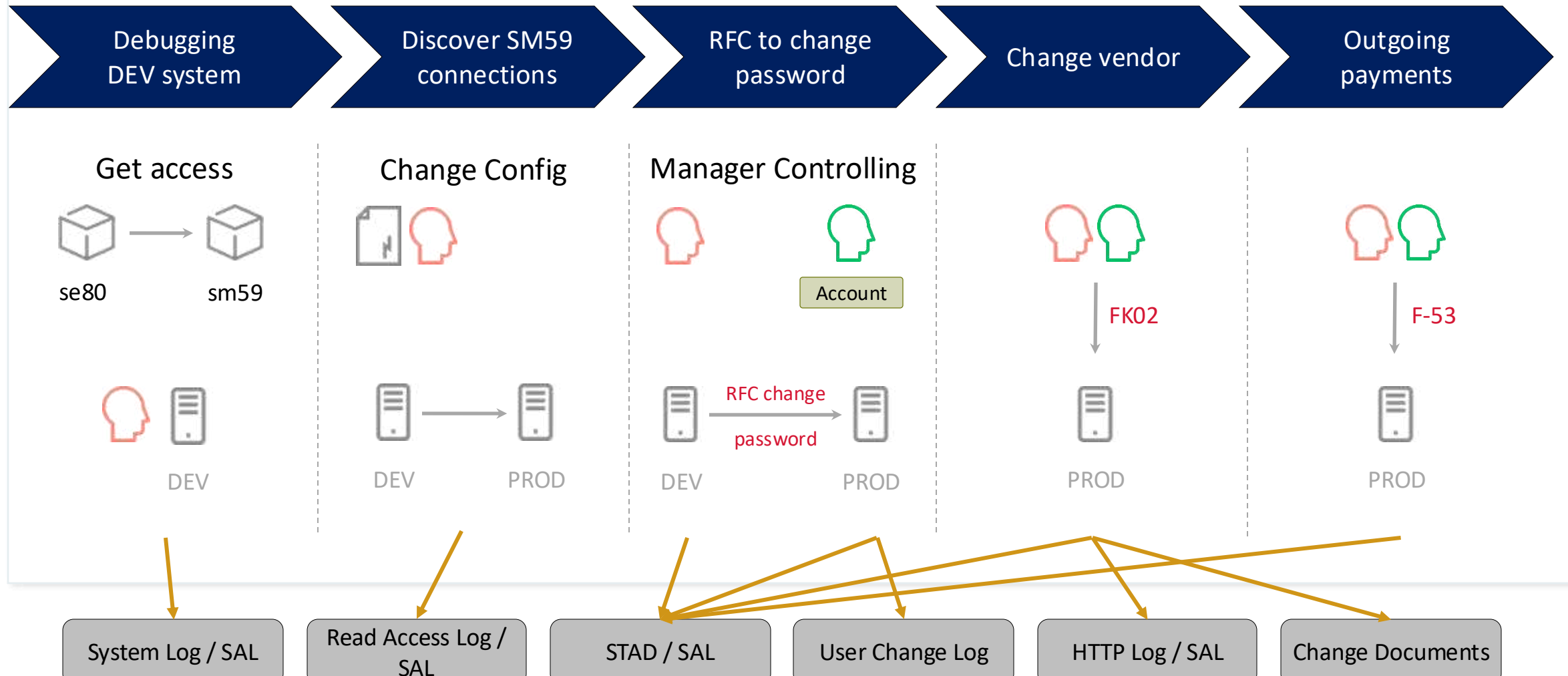
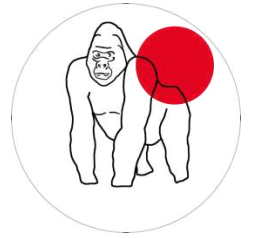
SAP and SOC Facts



- SAP Speaks its own language **SAPanese**
- Often times ran by dedicated IT Department
- Often monitored by a SAP Unit but only 9 - 5
- Often no to limited communication between cooperate SOC and SAP Security
- „Holistic Security“ often, sadly, excludes SAP Applications

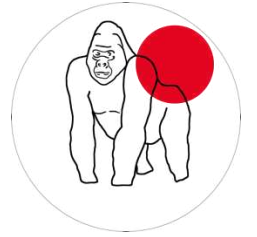


Detecting Attack





Detecting Attack



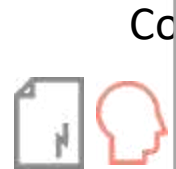
Debugging
DEV system

Disco
con

change vendor

Outgoing
payments

Get access



Co



DEV



DEV



FK02



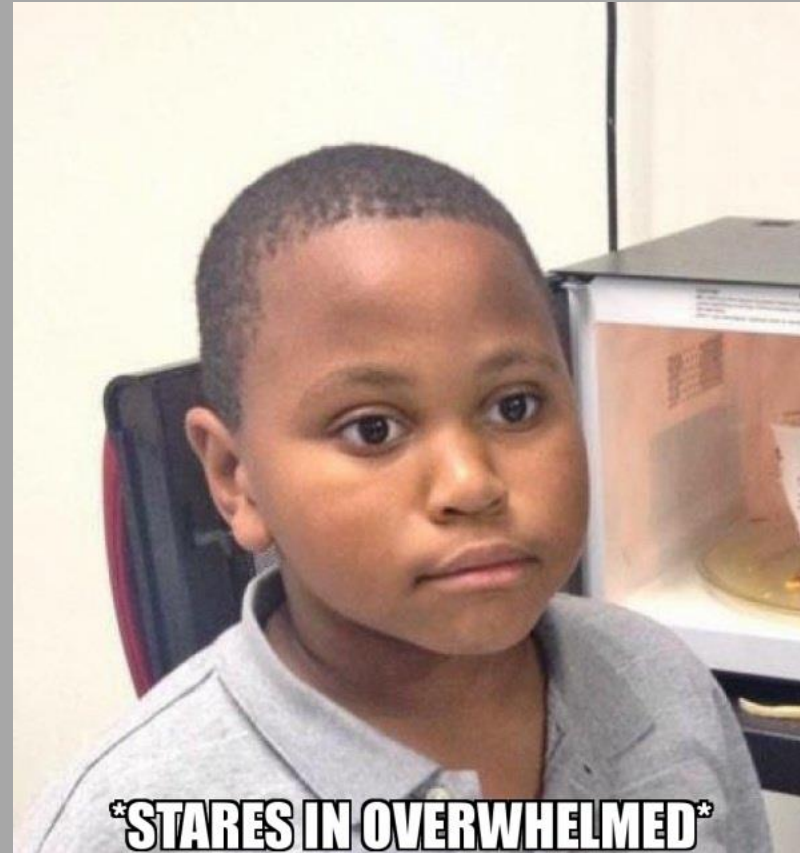
PROD



F-53



PROD



STARES IN OVERWHELMED

System Log / SAL

Read Access Log /
SAL

STAD / SAL

User Change Log

HTTP Log / SAL

Change Documents

SAP SAL data out of SOC perspective

Security Audit Log - Evaluation					
Evaluation of Security Audit Log					
Time	Message ID	TCode	Program	Audit Log Msg. Text	
18:33:34	AU5	S000	SAPMSSY1	RFC/CPIC logon successful (type=F, method=R)	
	AUK	S000	SAPMSSY1	Successful RFC call RSAU_READ_LOG (function group = RSAU_READ_LOG)	
18:33:30	AU3	SES...	SAPLSMTR_NAVIGATION	Transaction SM20 started.	
	AUW	SM20	RSAU_READ_LOG	Report RSAU_READ_LOG started	
18:33:24	AUD	SU01	SAPMSSY4	User master record SRODRIGUEZ changed.	
18:31:19	AU3	SES...	SAPMSSY4	Transaction SU01 started.	
	AUW	SU01	SAPMSSY4	Report SAPMSUU0 started	
18:31:07	AUD	SU01	SAPMSSY4	User master record SRODRIGUEZ changed.	
	AUB	SU01	SAPMSSY4	Authorizations for user SRODRIGUEZ changed.	
18:30:54	AU7	SU01	SAPMSSY4	User SRODRIGUEZ created.	

What is an TCode/Transaction?

- SU01?
- SM20?

What changed on SRODRIGUES after creation?

Was SRODRIGUES legitimately created?

SAP SAL data out of SOC perspective

What is an TCode?

- SU01?
- SM20?

Evaluation of Security

Time	Message ID	TCode	Program
18:33:34	AU5	S000	SAPMSSY
	AUK	S000	SAPMSSY
18:33:30	AU3	SES...	SAPLSMTI
	AUW	SM20	RSAU_RE
18:33:24	AUD	SU01	SAPMSSY
18:31:19	AU3	SES...	SAI Was
	AUW	SU01	slegitin
18:31:07	AUD	SU01	SAPMSSY
	AUB	SU01	SAPMSSY
18:30:54	AU7	SU01	SAPMSSY4

What changed on SRODRIGUES after creation?

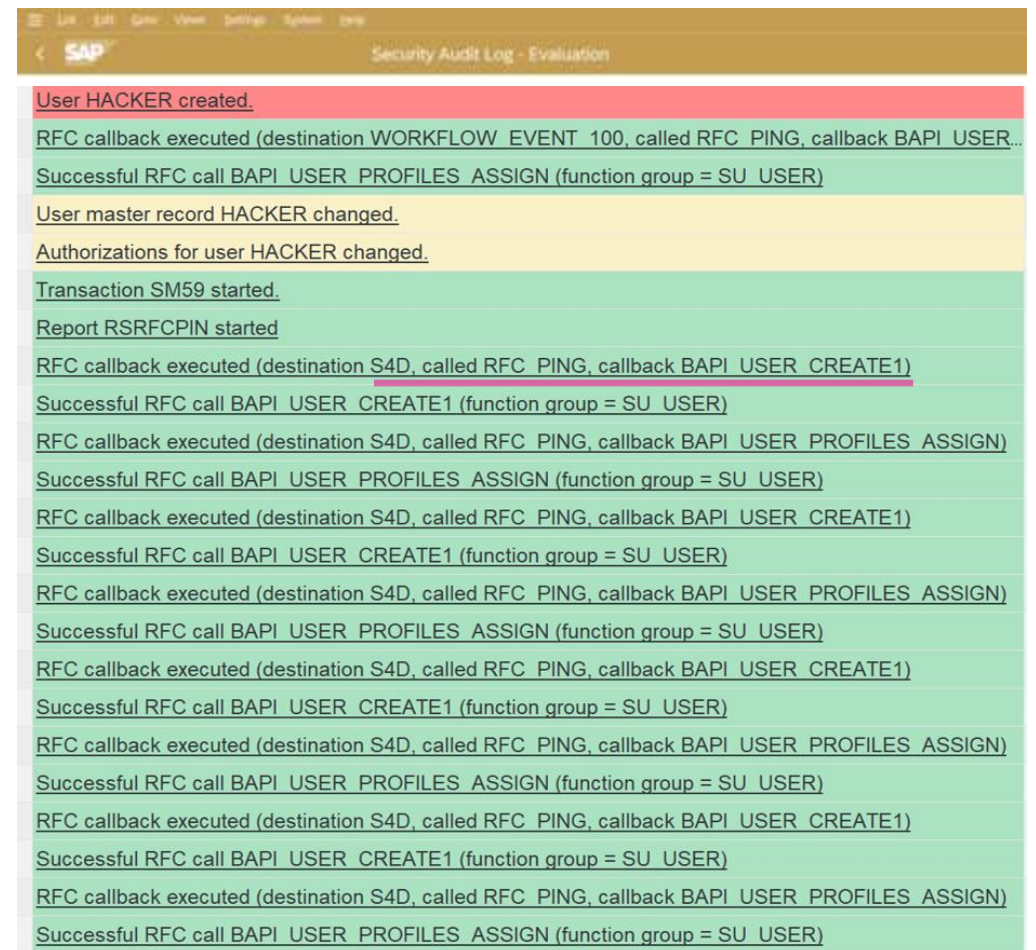
STARES IN OVERWHELMED

User SRODRIGUEZ created.

Attack Example: Malicious RFC Callback

Using destination "BACK" when calling function modules in ABAP to link back the execution to the originally calling system

- Event DUI is triggered for each RFC Callback execution
- In Standard classified non-critical event
- Usable as lateral movement. (Hosting your own mini sap)
- Hard to judge with no SAP background



The screenshot displays the SAP Security Audit Log - Evaluation interface. The log contains the following entries:

Event
User HACKER created.
RFC callback executed (destination WORKFLOW_EVENT_100, called RFC_PING, callback BAPI_USER_CREATE1)
Successful RFC call BAPI_USER_PROFILES_ASSIGN (function group = SU_USER)
User master record HACKER changed.
Authorizations for user HACKER changed.
Transaction SM59 started.
Report RSRFCPIN started
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_CREATE1)
Successful RFC call BAPI_USER_CREATE1 (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_PROFILES_ASSIGN)
Successful RFC call BAPI_USER_PROFILES_ASSIGN (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_CREATE1)
Successful RFC call BAPI_USER_CREATE1 (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_PROFILES_ASSIGN)
Successful RFC call BAPI_USER_PROFILES_ASSIGN (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_CREATE1)
Successful RFC call BAPI_USER_CREATE1 (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_PROFILES_ASSIGN)
Successful RFC call BAPI_USER_PROFILES_ASSIGN (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_CREATE1)
Successful RFC call BAPI_USER_CREATE1 (function group = SU_USER)
RFC callback executed (destination S4D, called RFC_PING, callback BAPI_USER_PROFILES_ASSIGN)
Successful RFC call BAPI_USER_PROFILES_ASSIGN (function group = SU_USER)

SAP on Mitre ATT&CK

SAL Event ID AUK – Successful RFC call

Always:

- T1078 - Valid Accounts

Contextual:

- Almost any tactic depending on called function module
- E.g. T1021 - Remote Services

The screenshot shows the SAP Data Browser interface for Table TFDIR. The main window has a title bar with 'ST1 (1) 100' and standard window controls. Below the title bar is a dark blue header with the text 'Data Browser: Table TFDIR: Selection Screen'. The main area contains a selection screen with various fields: FUNCNAME, PNAME, INCLUDE, FREEDATE, APPL, MAND, FMODE (set to 'R'), HOST, UTASK, PNAME_MAIN, RFCSCOPE, and RFCVERS. A modal window titled 'Display Number of Entries' is open in the foreground, displaying the text 'Number of entries that meet the selection criteria:' followed by the value '49,098' in a red box. At the bottom of the modal is a 'Close' button with a green checkmark. The background selection screen also has a 'Width of Output List' set to 250 and a 'Maximum No. of Hits' set to 200.

In the standard there are over 49.000 Remote procedure calls...

SOC Perspective on SAP with Mitre ATT&CK

SAL Event ID AUM

User &B Locked in Client &A
After Erroneous Password
Checks

Contextual:

- Credential Access:
Brute Force T1110.001
Password guessing
- Impact:
Account Access Removal T1531

or PEBCAK ...

- Overcoming SAP Lingo **SAPanese 101**
- Zero Trust / Assume breach
- Examples of cases given in Mitre DB
- Directly clear what would be worst case scenario

SOC Perspective on SAP with Mitre ATT&CK

SAL Event ID AUM

User &B Locked in Client &A
After Erroneous Password
Checks

Contextual:

- Credential Access:
Brute Force T1110.001
Password guessing
- Impact:
Account Access Removal T1531



or PEBCAK ...

Keypoints on SAP and Mitre ATT&CK



Multiple events can have the same ATT&CK ID's



A single event can have multiple ATT&CK ID's



Threat Modeling needs to be done cross department



Mapping needs to be done manually... currently...



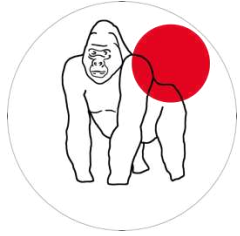
No OOTB mapping available.. To be released soon!

Want to have your own SAP?



- Deployment of:
 - SAPRouter
 - SAP Cloud Connector
 - SAP System (S/4HANA)





Next Steps



Roadmap



Webpage



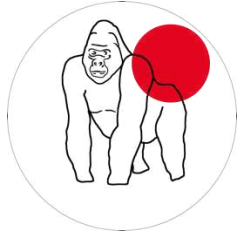
OpenSSF



Combine



Endorsement

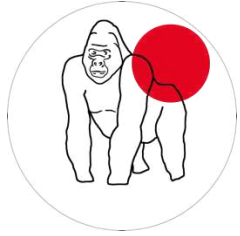


Supporters

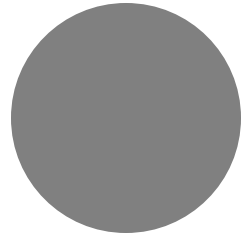


Supporters





Contributors



Q&A



julian@hathor  docker run --rm -it ghcr.io/securitysilverbacks/sap-attacksurfacediscovery:latest|